9.03 Security measures for protecting computer systems

Disaster recovery

Continuity of operation is vital for large computer installations that are an integral part of the day-to-day operations of an organisation. Measures are needed to ensure that the system continues working whatever event occurs or, if there has to be a system shut-down, at the very least to guarantee that the service will start again within a very short time.

Such measures come under the general heading of disaster recovery contingency planning. The contingency plan should be based on a risk assessment. The plan will have provision for an alternative system to be brought into action. If an organisation has a full system always ready to replace the normally operational one, it is referred to as a 'hot site'. By definition, such a system has to be remote from the original system to allow recovery from natural disasters such as earthquake or flood.

Safe system update

A special case of system vulnerability arises when there is a major update of hardware and/or software. Traditionally, organisations had the luxury of installing and testing a new system over a weekend when no service was being provided. In the modern era, it is more usual to have systems that can be accessed at any time and (often) from any location. A company is never closed for business. As a result, organisations may need to have the original system and its replacement running in parallel for a period to ensure continuity of service.

Discussion Point:

Major failings of large computer systems are well documented. You could carry out research to find some examples. Find an example of where the crisis was caused by technology failure and a different example where some natural disaster was the cause.

User authentication

Even if a PC is used by only one person there should be a user account set up. User accounts are, of course, essential for a multi-user (timesharing) system. The main security feature of a user account is the **authentication** of the user. The normal method is to associate a password with each account. In order for this to be effective the password needs a large number of characters including a variety of those provided in the ASCII scheme.



KEY TERM

Authentication: verification of a user's identity

TASK 9.01

1. Create an example of a secure password using eight characters (but not one you are going to use).
2. Assuming that each character is taken from the ASCII set of graphic characters, how many different possible passwords could be defined by eight characters?
3. Do you think this is a sufficient number of characters to assume that the password would not be encountered by someone trying all possible passwords in turn to access the system?

Alternative methods of authentication include biometric methods and security tokens. A biometric method might require examination of a fingerprint or the face or the eye. A security token can be a small item of hardware provided for each individual user that confirms their identity. Similar protection can be provided by software with the user required to provide further input after the password has been entered. Normal practice is to combine one of these alternative methods with the password system.

Good practice

General good practice that helps to keep a personal computer secure includes not leaving the computer switched on when unattended, not allowing someone else to observe you accessing the computer and not writing down details of how you access it.

Users may attach portable storage devices to a system, but this increases the risk of transferring malware into the system. This risk is reduced by an organisation having a policy banning the use of such devices or at least limiting their use. Unfortunately, this is difficult if normal business processes require portability of data.

Firewall

The primary defence to malware entering a system through a network connection is to install a **firewall**. Ideally a firewall will be a hardware device that acts like a security gate at an international airport. Nothing is allowed through without it being inspected. Alternatively, a firewall can run as software. Data must enter the system, but it can be inspected immediately. A firewall can inspect the system addresses identified in the transmission of data, but can sometimes also inspect the data itself to check for anything unusual or inappropriate.

KEY TERM

Firewall: hardware or software that monitors and controls network traffic

Digital signature

If an incoming transmission is an email, you might want to check the identity of the sender. The solution is to insist that the sender attaches a digital signature to the email. Some details of this are discussed in Chapter 21 (Section 21.02).

Anti-virus software and intrusion detection

Security measures restricting access to a system do not guarantee success in removing all threats. It is therefore necessary to have, in addition, programs running on a system to check for problems. One option is to install what is normally referred to as anti-virus software but which is usually aimed at combating any type of malware. This carries out regular scans to detect any malware and to remove or deactivate it. Possibly special-purpose anti-spyware software might be installed. Another option is to install an intrusion detection system that will take as input an audit record of system use and look for examples that do not match expected system activity.

Unfortunately, people intent on causing damage to systems are using methods that are becoming ever more sophisticated. The defence methods have to be improved continually to counter these threats.

9.04 Security measures for protecting data

Recovering from data loss

In addition to problems arising from malicious activity there are a variety of reasons for accidental loss of data:

- a disk or tape gets corrupted
- a disk or tape is destroyed
- the system crashes
- the file is erased or overwritten by mistake
- the location of the file is forgotten.

For these reasons, every system should have a backup procedure to recover lost data. The system administrator decides on the details of the procedure. The principles for the procedure traditionally followed are straightforward:

- a full backup is made at regular intervals, perhaps weekly
- at least two generations of full backup are kept in storage
- incremental backups are made on a daily basis.

For maximum security the backup disks or tapes are stored away from the system in a fire-proof and flood-proof location.

This works well when an incremental backup occurs done overnight with the full backup handled at the weekend. With systems running 24/7, data in the system might be changing at any time, and a simple approach to backup would leave data in an inconsistent state.

One solution is to have a backup program that effectively freezes the file store while data is being copied. At the same time changes that are happening due to system use are recorded elsewhere within the system. The changes can then be implemented once the backup copy has been stored.

An alternative approach is to use a disk-mirroring strategy. In this case, data is simultaneously stored on two disk systems during the normal operation of the system. The individual disk systems might be at remote locations as part of a disaster recovery plan.

Restricting access to data

If a user has logged in, they have been authorised to use the computer system but not necessarily all of it. In particular, the system administrator may identify different categories of user with different needs with respect to the data they are allowed to see and use. A typical example is that one employee should be able to use the system to look up another employee's internal phone number. This should not allow the employee at the same time to check the salary paid to the other employee.

The solution is to have an **authorisation** policy which gives different access rights to different files for different individuals. For a particular file, a particular individual might have no access at all or possibly read access but not write access. In another case, an individual might have read access but not unrestricted write access.

KEY TERM

Authorisation: definition of a user's access rights to system components

Protecting data content

Even with appropriate security measures in place, a system and its data might still be accessed by someone who overcomes security to break into the system. This type of access can still be made a waste of time and effort if the stored data cannot be read. Data can be encrypted to ensure this. Some details of encryption methods are discussed in Chapter 21 (Sections 21.01, 21.03, 21.04, 21.05 & 21.06).

9.05 Data validation and verification

Data integrity can never be guaranteed, but the chances are improved if appropriate measures are taken when data originally enters a system or when it is transmitted from one system to another.

Validation of data entry

The term **validation** is a somewhat misleading one. It seems to imply that data is accurate if it has been validated. This is far from the truth. For example, if entry of a name is expected but the wrong name is entered, it will still be recognised as a name and therefore accepted as valid. Validation can only prevent incorrect data if there is an attempt to input data that is of the wrong type, in the wrong format or out of range.

Data validation is implemented by software associated with a data entry interface. There are a number of different types of check that can be made. Typical examples are:

- a presence check to ensure that an entry field is not left blank
- a format check, for example a date has to be dd/mm/yyyy
- a length check, for example with a telephone number
- a range check, for example the month in a date must not exceed 12
- a limit check, for example a maximum number of years for a person's age
- a type check, for example only a numeric value for the month in a date
- an existence check, for example that a file exists with the filename referred to in the data entry.

Verification of data entry

When data is entered into a system, **verification** means getting the user to confirm that the data entered was what was intended to be entered. Unfortunately, this still does not mean that the data entered is correct. Double entry is one method of verification. The most common example is when a user is asked to supply a new password. There will usually be a request for the password to be re-entered. A second method is to use a visual check of what has been entered. If a form has been filled in, it always makes sense to read through the data entered before sending the form off to its destination.

Check digit

When a series of numbers are used to identify something, it is possible to use a check digit method of verification. There are many different options here but they all require a calculation to be made with the numbers that have been entered. The final part of the calculation involves an integer division from which the remainder is added as an extra one or two digits at the end of the series of numbers. In one scheme where only a single check digit is allowed, the letter X is used when the remainder is calculated as 10. When the data is subsequently read the same calculation is carried out and the result is compared to the check digit that had been stored. This technique is used for a bar code or for the ISBN for a book.